LAPORAN PRAKTIKUM DEVSECOPS
KELOMPOK 3

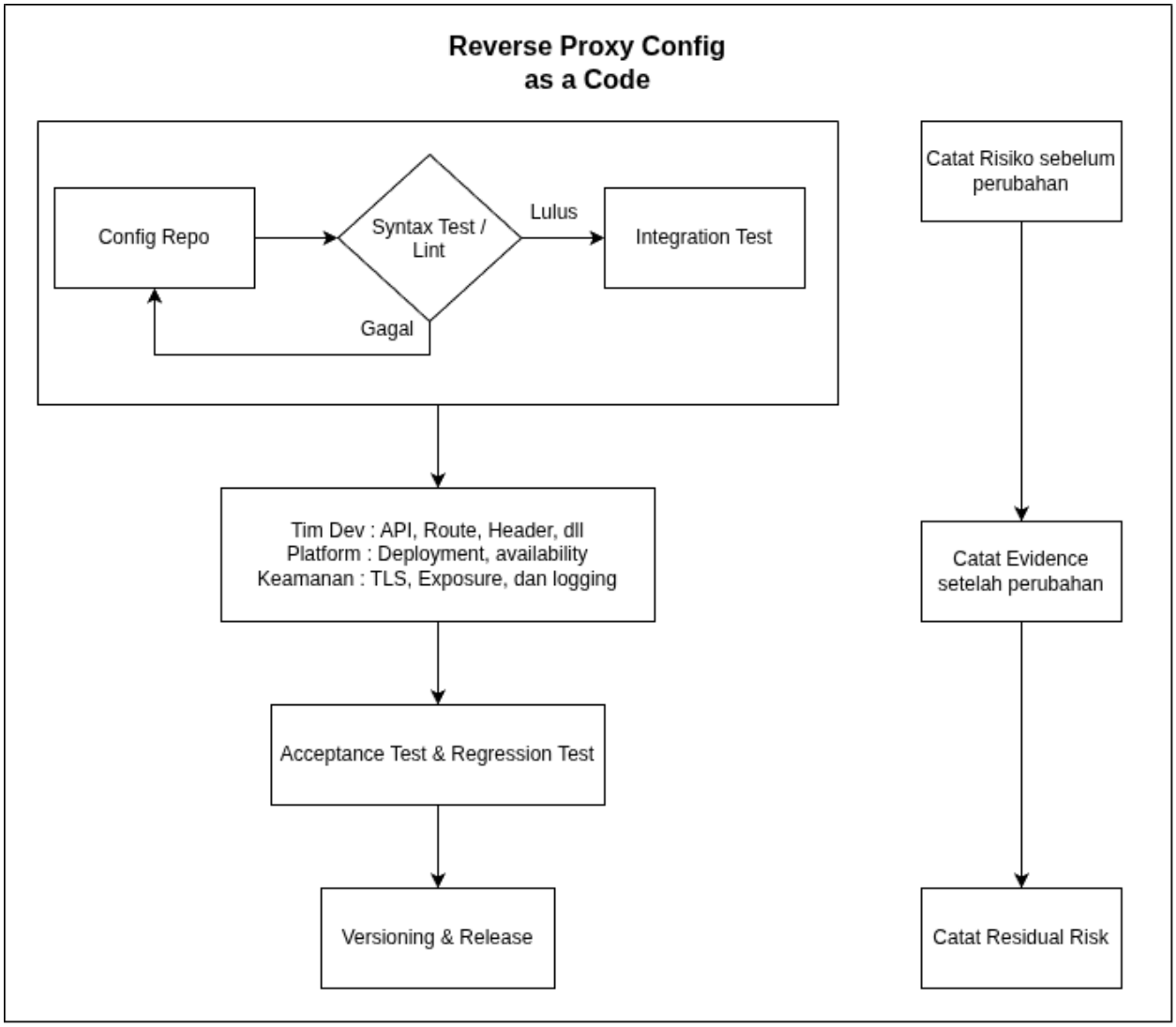


Nama	: Muhammad Rafi Putra Hidayat
	Hafidz Kurnia Darojad
	Indra Rahmat Maulidi
	Moh Iqbal Triwijaya
NRP	: 3124600009
	3124600015
	3124600017
	3126640015
Dosen Pengajar	: Ferry Astika Saputra, ST., M.Sc

PROGRAM STUDI D4 TEKNIK INFORMATIKA

POLITEKNIK ELEKTRONIKA NEGERI SURABAYA (PENS)

TAHUN 2026


Reverse Proxy Config
as a Code
Config Repo
Syntax Test /
Lint
Lulus
Integration Test
Gagal
Tim Dev : API, Route, Header, dll
Platform : Deployment, availability
Keamanan : TLS, Exposure, dan logging
Acceptance Test & Regression Test
Versioning & Release
Catat Risiko sebelum
perubahan
Catat Evidence
setelah perubahan
Catat Residual Risk

Verifikasi dan Skenario Pengujian

[ ] Nginx reverse proxy dapat mengakses Apache melalui nama service.

```
student@student:~/docker-lab/bab-4$ curl -I http://localhost:8080/
HTTP/1.1 301 Moved Permanently
Server: nginx/1.31.6
Date: Tue, 29 Sep 2026 05:45:05 GMT
Content-Type: text/html
Content-Length: 169
Connection: keep-alive
Location: https://localhost:8443/

student@student:~/docker-lab/bab-4$ curl -k -i https://localhost:8443/
HTTP/1.1 200 OK
Server: nginx/1.31.6
Date: Tue, 29 Sep 2026 05:45:09 GMT
Content-Type: text/html
Content-Length: 282
Connection: keep-alive
Last-Modified: Tue, 29 Sep 2026 05:30:12 GMT
ETag: "11a-65c987a0b7c11"
Accept-Ranges: bytes
X-Content-Type-Options: nosniff
X-Frame-Options: DENY
Referrer-Policy: no-referrer

<!DOCTYPE html>
<html lang="id">
<head>
    <meta charset="UTF-8">
    <title>DevSecOps Bab 4</title>
</head>
<body>
    <h1>Apache di Belakang Nginx</h1>
    <p>Halaman Bab 4 berhasil dilayani melalui reverse proxy.</p>
    <p><a href="/api/">Uji Flask API</a></p>
</body>
</html>
```

[ ] Endpoint /api diarahkan ke backend Flask.

```
student@student:~/docker-lab/bab-4$ curl -k -i https://localhost:8443/api/
HTTP/1.1 200 OK
Server: nginx/1.31.6
Date: Tue, 29 Sep 2026 05:46:00 GMT
Content-Type: application/json
Content-Length: 117
Connection: keep-alive
X-Content-Type-Options: nosniff
X-Frame-Options: DENY
Referrer-Policy: no-referrer

{"forwarded_proto":"https","message":"API Bab 4 berhasil diakses melalui Nginx","service":"flask-app","status":"ok"}
```

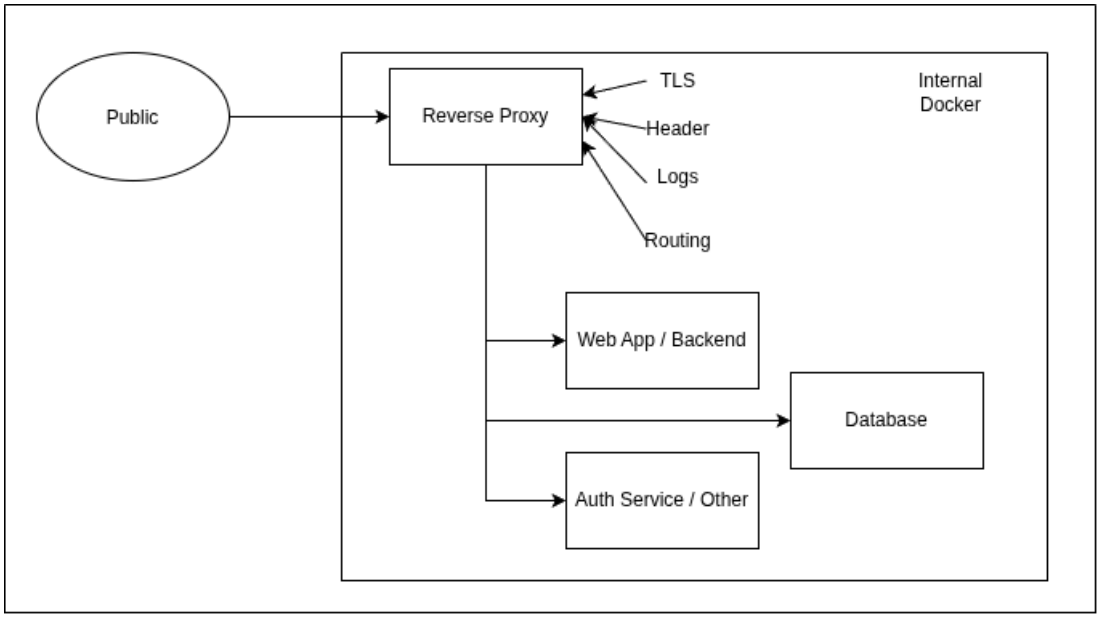
[ ] HTTPS self-signed berjalan di port 8443.

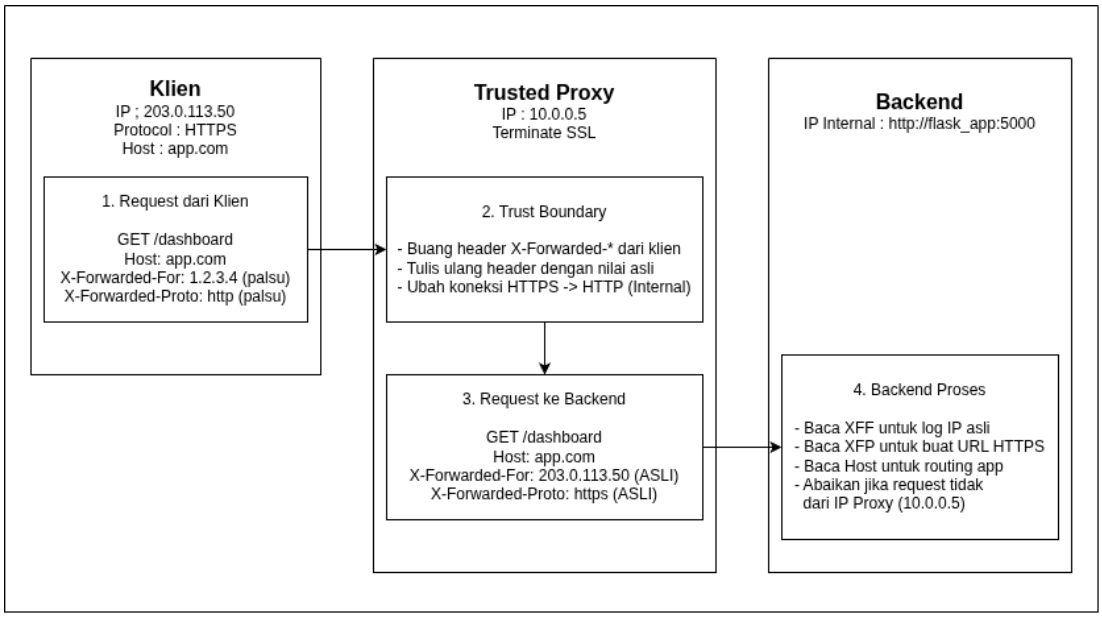
```
student@student:~/docker-lab/bab-4$ openssl s_client   -connect localhost:8443   -servername localhost   -brief </dev/null
depth=0 CN = localhost, O = DevSecOps Docker Lab
verify error:num=18:self-signed certificate
CONNECTION ESTABLISHED
Protocol version: TLSv1.3
Ciphersuite: TLS_AES_256_GCM_SHA384
Peer certificate: CN = localhost, O = DevSecOps Docker Lab
Hash used: SHA256
Signature type: RSA-PSS
Verification error: self-signed certificate
Server Temp Key: X25519, 253 bits
DONE
```

[ ] Access log tersimpan di direktori host.

```
student@student:~/docker-lab/bab-4$ ls -lh logs/nginx/
tail -n 10 logs/nginx/access.log
total 8.0K
-rw-r--r-- 1 root root 828 Sep 29 05:46 access.log
-rw-r--r-- 1 root root 490 Sep 29 05:33 error.log
172.20.0.1 - - [29/Sep/2026:05:33:25 +0000] "HEAD / HTTP/1.1" 301 0 "-" "curl/8.5.0" "-"
172.20.0.1 - - [29/Sep/2026:05:34:14 +0000] "GET / HTTP/1.1" 200 282 "-" "curl/8.5.0" "-"
172.20.0.1 - - [29/Sep/2026:05:34:28 +0000] "GET /api/ HTTP/1.1" 200 117 "-" "curl/8.5.0" "-"
172.20.0.1 - - [29/Sep/2026:05:34:35 +0000] "GET /api/health HTTP/1.1" 200 21 "-" "curl/8.5.0" "-"
172.20.0.1 - - [29/Sep/2026:05:45:01 +0000] "HEAD / HTTP/1.1" 301 0 "-" "curl/8.5.0" "-"
172.20.0.1 - - [29/Sep/2026:05:45:03 +0000] "GET /api/ HTTP/1.1" 200 117 "-" "curl/8.5.0" "-"
172.20.0.1 - - [29/Sep/2026:05:45:05 +0000] "HEAD / HTTP/1.1" 301 0 "-" "curl/8.5.0" "-"
172.20.0.1 - - [29/Sep/2026:05:45:09 +0000] "GET / HTTP/1.1" 200 282 "-" "curl/8.5.0" "-"
172.20.0.1 - - [29/Sep/2026:05:46:00 +0000] "GET /api/ HTTP/1.1" 200 117 "-" "curl/8.5.0" "-"
```

[ ] Mahasiswa mampu menjelaskan alur request client-proxy-backend.





Evaluasi dan Latihan Mandiri

1. Mengapa reverse proxy tidak seharusnya menjalankan semua logic aplikasi?

- Pemisahan Peran: Reverse proxy fokus mengelola lalu lintas jaringan (TLS termination, routing, rate limiting, caching), bukan aturan bisnis aplikasi.
- Performa Arsitektur: Nginx berbasis event-driven non-blocking. Eksekusi komputasi berat atau query database lambat di proxy akan menahan worker process dan menurunkan kecepatan akses seluruh pengguna.
- Keamanan: Memisahkan lapisan depan mencegah kerentanan kode aplikasi langsung merusak kontrol gerbang routing utama.

2. Apa perbedaan TLS termination dan end-to-end TLS?

- TLS Termination: Lalu lintas didekripsi di reverse proxy; komunikasi dari proxy ke backend menggunakan HTTP biasa. Praktis dan menghemat beban CPU backend, tetapi segmen jaringan internal tidak terenkripsi.
- End-to-End TLS: Enkripsi dipertahankan dari klien langsung hingga ke backend (atau dienkripsi ulang dari proxy via mTLS). Menerapkan prinsip Zero Trust sehingga aman dari penyadapan internal, meski membutuhkan beban komputasi dan pengelolaan sertifikat di setiap service.

3. Bagaimana cara mengisolasi backend agar tidak langsung diakses dari host?

- Hapus deklarasi ports: Jangan memetakan port host ke backend pada compose.yaml.
- Gunakan User-Defined Bridge Network: Letakkan proxy dan backend dalam satu network privat yang sama. Nginx memanggil backend via DNS internal Docker (http://flask-app:5000), sementara interface host sama sekali tidak membuka port tersebut.

4. Apa konsekuensi menyimpan private key TLS di bind mount?

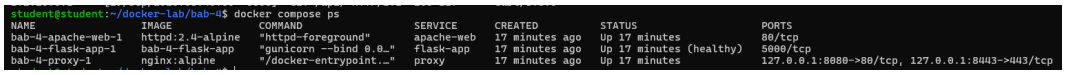
- Kebocoran Git: Rentan terunggah ke repositori publik jika lupa dimasukkan ke .gitignore.
- Akses Izin Host: User non-root di sistem operasi host berpotensi membaca file kunci jika hak akses tidak dikunci (chmod 600).
- Risiko Modifikasi: Jika tidak di-mount dengan flag read-only (:ro), kontainer yang terkompromi dapat mengubah atau merusak kunci di host.
- Solusi: Solusinya adalah mengunci private key di host (chmod 600), mengecualikannya dari Git via .gitignore, lalu memasangnya ke Nginx saat runtime sebagai volume read-only (:ro) atau Docker Secret. Rotasi sertifikat dilakukan cukup dengan perintah nginx -s reload tanpa rebuild image, sementara keamanan TLS dioptimalkan lewat protokol minimum TLSv1.2 TLSv1.3

5. Bandingkan log Nginx dan log Apache dari sisi format dan kegunaan debugging.

- Nginx Log: Unggul untuk debugging jaringan dan gateway. Formatnya padat dan langsung menunjukkan akar masalah reverse proxy, seperti kegagalan upstream (502/504), negosiasi SSL, dan latensi proxy.
- Apache Log: Unggul untuk debugging modul dan file server. Formatnya mencantumkan nama modul spesifik, berguna mendiagnosis error izin file sistem, aturan .htaccess, dan konfigurasi virtual host internal.

Bukti minimum:

Screenshot docker compose ps atau docker ps yang menunjukkan service berjalan.



Screenshot hasil curl/browser/API/dashboard sesuai target bab.

- Uji HTTP

```
student@student:~/docker-lab/bab-4$ curl -I http://localhost:8080/
HTTP/1.1 301 Moved Permanently
Server: nginx/1.31.6
Date: Tue, 29 Sep 2026 05:53:09 GMT
Content-Type: text/html
Content-Length: 169
Connection: keep-alive
Location: https://localhost:8443/
```

- Uji HTTPS

```
student@student:~/docker-lab/bab-4$ curl -k -i https://localhost:8443/
HTTP/1.1 200 OK
Server: nginx/1.31.6
Date: Tue, 29 Sep 2026 05:53:13 GMT
Content-Type: text/html
Content-Length: 282
Connection: keep-alive
Last-Modified: Tue, 29 Sep 2026 05:30:12 GMT
ETag: "11a-65c987a0b7c11"
Accept-Ranges: bytes
X-Content-Type-Options: nosniff
X-Frame-Options: DENY
Referrer-Policy: no-referrer

<!DOCTYPE html>
<html lang="id">
<head>
    <meta charset="UTF-8">
    <title>DevSecOps Bab 4</title>
</head>
<body>
    <h1>Apache di Belakang Nginx</h1>
    <p>Halaman Bab 4 berhasil dilayani melalui reverse proxy.</p>
    <p><a href="/api/">Uji Flask API</a></p>
</body>
</html>
```

- Uji Flask API via HTTPS

```
student@student:~/docker-lab/bab-4$ curl -k -i https://localhost:8443/api/
HTTP/1.1 200 OK
Server: nginx/1.31.6
Date: Tue, 29 Sep 2026 05:53:17 GMT
Content-Type: application/json
Content-Length: 117
Connection: keep-alive
X-Content-Type-Options: nosniff
X-Frame-Options: DENY
Referrer-Policy: no-referrer

{"forwarded_proto":"https","message":"API Bab 4 berhasil diakses melalui Nginx","service":"flask-app","status":"ok"}
```

- Uji Health check

```
student@student:~/docker-lab/bab-4$ curl -k -i https://localhost:8443/api/health
HTTP/1.1 200 OK
Server: nginx/1.31.6
Date: Tue, 29 Sep 2026 05:53:32 GMT
Content-Type: application/json
Content-Length: 21
Connection: keep-alive
X-Content-Type-Options: nosniff
X-Frame-Options: DENY
Referrer-Policy: no-referrer

{"status":"healthy"}
```

Cuplikan log atau query yang membuktikan sistem bekerja.

```
student@student:~/docker-lab/bab-4$ ls -lh logs/nginx/
tail -n 10 logs/nginx/access.log
total 8.0K
-rw-r--r-- 1 root root 828 Sep 29 05:46 access.log
-rw-r--r-- 1 root root 490 Sep 29 05:33 error.log
172.20.0.1 - - [29/Sep/2026:05:33:25 +0000] "HEAD / HTTP/1.1" 301 0 "-" "curl/8.5.0" "-"
172.20.0.1 - - [29/Sep/2026:05:34:14 +0000] "GET / HTTP/1.1" 200 282 "-" "curl/8.5.0" "-"
172.20.0.1 - - [29/Sep/2026:05:34:28 +0000] "GET /api/ HTTP/1.1" 200 117 "-" "curl/8.5.0" "-"
172.20.0.1 - - [29/Sep/2026:05:34:35 +0000] "GET /api/health HTTP/1.1" 200 21 "-" "curl/8.5.0" "-"
172.20.0.1 - - [29/Sep/2026:05:45:01 +0000] "HEAD / HTTP/1.1" 301 0 "-" "curl/8.5.0" "-"
172.20.0.1 - - [29/Sep/2026:05:45:03 +0000] "GET /api/ HTTP/1.1" 200 117 "-" "curl/8.5.0" "-"
172.20.0.1 - - [29/Sep/2026:05:45:05 +0000] "HEAD / HTTP/1.1" 301 0 "-" "curl/8.5.0" "-"
172.20.0.1 - - [29/Sep/2026:05:45:09 +0000] "GET / HTTP/1.1" 200 282 "-" "curl/8.5.0" "-"
172.20.0.1 - - [29/Sep/2026:05:46:00 +0000] "GET /api/ HTTP/1.1" 200 117 "-" "curl/8.5.0" "-"
```

Analisis Wajib

Jelaskan satu masalah yang muncul dan cara Anda mendiagnosisnya.

Jawab : Tidak ada.

Jelaskan risiko keamanan atau operasional yang relevan pada bab ini.

Jawab : Penyimpanan Private Key di Bind Mount. File certs/lab.key yang disimpan di bind mount host dapat dibaca oleh user lain di sistem host jika hak akses (file permission) tidak dikunci (misal 600).

Berikan rekomendasi perbaikan bila lab ini akan dibawa ke production-like environment.

Jawab : Hindari menyimpan private key di bind mount biasa. Gunakan fitur Docker Secrets, Kubernetes Secrets, atau Vault Service lain dengan mode pemuatan read-only saat runtime.